

Enterprise AI Authentication Research • Part 4 of 7

Part 4

Agent Runtime, MCP Security & Governance

Agent runtimes, MCP/A2A protocols, Zero Trust security, RBAC/ABAC/PBAC governance, and complete audit chains

Enterprise Authentication & Identity Propagation for AI Agents

Agent Runtime — Authentication Context

Agent runtimes are the execution environments in which AI agents invoke tools, manage state, and orchestrate multi-step workflows. How authenticated context is passed through the runtime — and what each tool receives — determines the security properties of the entire agentic system.

Major Agent Runtimes Compared

Agent Runtime Comparison

Runtime	Auth Context Passing	User Identity	MCP Support	Production Use
MCP (Model Context Protocol)	HTTP headers / OAuth per tool	Per-tool user token	Native (is MCP)	Claude, custom agents
A2A (Agent-to-Agent, Google)	AgentCard + JWT bearer	Sub claim in JWT	Compatible	Google ADK, enterprise agents
Function Calling (OpenAI/Anthropic)	Context in system prompt + tool result	Not standardised — implementation-specific	Via adapter	GPT-4, Claude API
LangGraph	Runnable config (configurable fields)	Injected via RunnableConfig or State	Via MCP tools node	LangChain ecosystem
Amazon Bedrock AgentCore	AWS IAM + STS AssumeRole	IAM principal (user or role)	Via action groups	AWS-native agents
Google ADK	Service account + user delegation	OIDC sub claim	Vertex Extensions	Google Cloud agents
OpenAI Responses API	API key + user param	user string (opaque)	Via tools	ChatGPT, custom GPTs

What Context Should Every Tool Receive?

A well-designed agent runtime passes rich context with every tool invocation — not just an OAuth token. The following context enables authorization, audit, and governance at the tool layer.

Tool Context Requirements

Context Field	Purpose	Passed By	Required?
User Identity (sub/UPN/email)	Identify acting user	Auth token / header	YES — mandatory
Tenant / Org ID	Multi-tenant isolation	Token claim / header	YES — for SaaS systems
Roles / Groups	RBAC authorization at tool	Token claims	Recommended

Context Field	Purpose	Passed By	Required?
Custom Claims (ABAC attrs)	Fine-grained attribute-based authz	Token claims / header	For sensitive tools
Conversation / Session ID	Audit correlation	Header (X-Conversation-ID)	YES — for audit
Trace ID	Distributed tracing	OpenTelemetry traceparent header	Highly recommended
Span ID	Per-tool call tracking	OpenTelemetry	Recommended
Agent ID	Identify which agent is calling	Header / JWT actor claim	YES — for agent audit
Request Timestamp	Replay prevention	Header or JWT iat claim	Recommended
Scope List	Explicit scope boundary	OAuth scope claim	YES — prevent scope creep

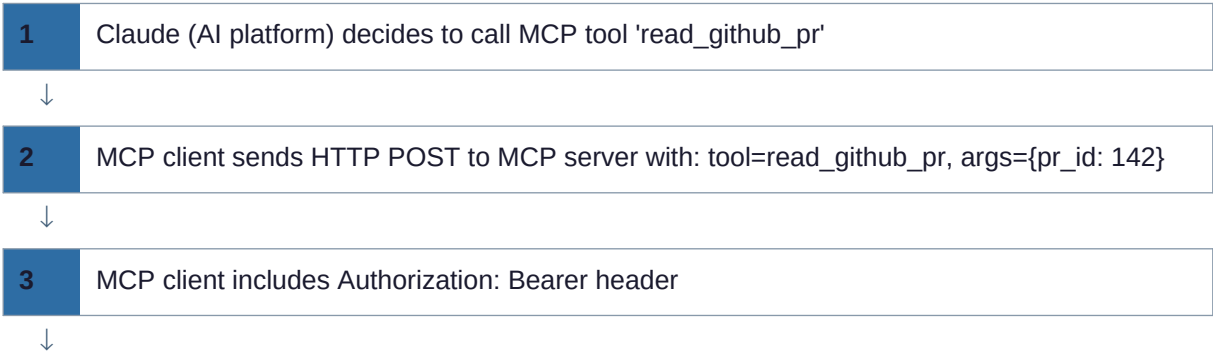
MCP — Model Context Protocol Security

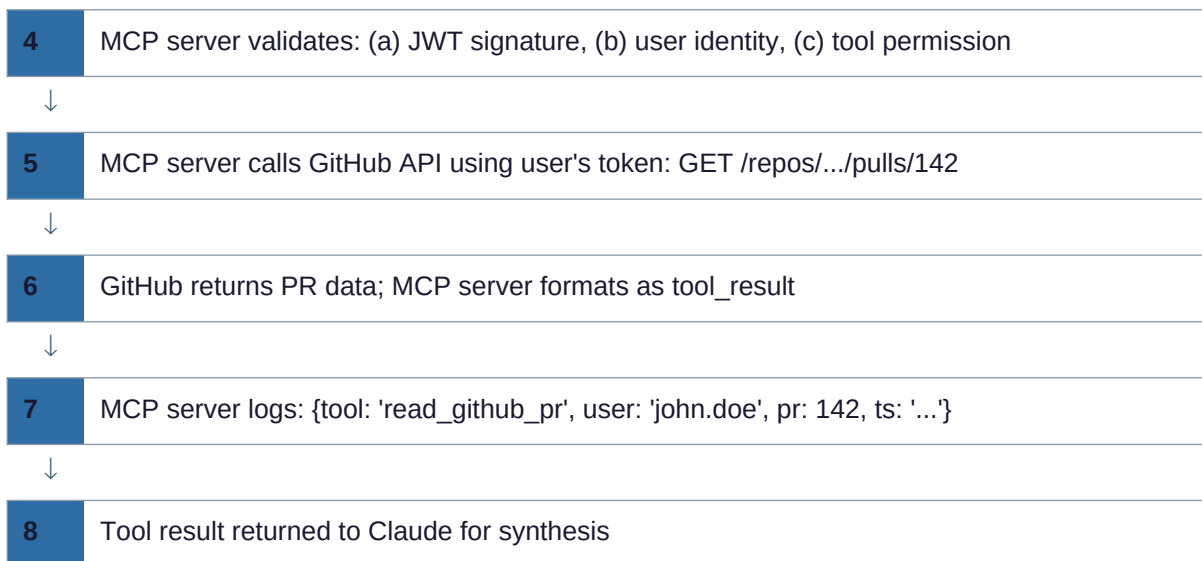
MCP is Anthropic's open standard for AI tool integration. An MCP server exposes a set of tools (functions) that an AI can call. Security in MCP is primarily the responsibility of the MCP server — it must validate the caller's identity and enforce authorization before executing any tool.

MCP Server Security Requirements

- Authenticate every tool invocation — do not trust tool calls without verified identity
- Use OAuth 2.0 or signed JWTs for MCP server authorization (MCP auth spec, 2024)
- Validate the AI platform identity (who is calling the MCP server) separately from user identity
- Enforce tool-level authorization: not all users should access all tools on an MCP server
- Log every tool call with: tool_name, user_id, timestamp, input schema, outcome
- Implement rate limiting per user and per tool to prevent abuse
- Reject tool schemas containing unexpected parameters (prompt injection vectors)

MCP Tool Invocation Security Flow





A2A — Agent-to-Agent Protocol (Google)

Google's A2A protocol defines how AI agents communicate with each other in a standardised way. Agent identity is established through an AgentCard — a well-known JSON document describing the agent's capabilities and authentication requirements. A2A security relies on JWT bearer tokens with the acting user's identity preserved in the 'sub' claim.

A2A Protocol Security Properties

A2A Security Dimension	Implementation
Agent Authentication	AgentCard at /.well-known/agent.json; JWT bearer for API calls
User Identity Propagation	user_id field in A2A message; sub claim in bearer JWT
Trust Establishment	Agent registers with enterprise registry; admin approves AgentCard
Authorization	Receiving agent validates caller agent's identity AND user identity
Audit	Each A2A message includes trace_id for end-to-end correlation
Replay Prevention	JWT iat + exp claims; nonce in message body

Security — Zero Trust for AI Agents

Zero Trust architecture treats every request — even from inside the corporate network — as potentially hostile. For AI agents, this means every tool call must be authenticated, authorized, and logged, regardless of where the agent is running.

Zero Trust Principles Applied to AI Agents

Zero Trust Principles for AI Agents

Principle	AI Agent Application	Implementation
Verify Explicitly	Authenticate every tool call	OAuth tokens per tool; no implicit trust based on network location
Use Least Privilege	Minimal scopes per tool	Request only read scopes unless write is explicitly needed for the task
Assume Breach	Expect tokens will be stolen	Short token lifetimes; CAE; anomaly detection on token use patterns
Micro-segmentation	Isolate tool access	Agent cannot call GitHub with the same token used for ServiceNow
Device Health	Validate agent runtime integrity	Agent image signing; attestation; no unapproved plugins
Data Classification	Respect sensitivity labels	AI output filtered by data classification of sources used

Security Threat Taxonomy for AI Agents

AI Agent Security Threats and Mitigations

Threat	Description	Mitigation
Prompt Injection	Malicious content in tool results instructs AI to take unauthorized actions	Sanitise tool outputs before passing to LLM; output validation; human approval gates
Tool Injection	Malicious MCP server exposes dangerous tools not approved by admin	Allowlist MCP servers; validate tool schemas; sign MCP server manifests
Identity Spoofing	Attacker claims to be a different user in the AI context	Validate identity from trusted IdP token only; reject self-asserted identity
Session Hijacking	Attacker steals session cookie or access token	HttpOnly cookies; token binding; anomaly detection; CAE revocation

Threat	Description	Mitigation
Replay Attack	Old token reused after expiry	Short token lifetimes; nonce validation; token binding; CAE
Token Theft	Access token extracted from logs, prompts, or storage	Never log tokens; encrypt at rest; do not include in LLM prompt
Confused Deputy	AI platform acts with elevated permissions it received but user doesn't have	Always use delegated (user) tokens for user-driven actions; validate scopes
Privilege Escalation	Agent uses capabilities beyond what user authorised	Scope validation at tool layer; deny by default; explicit capability grants
Cross-Agent Attacks	Malicious agent poisons shared memory or context	Agent isolation; signed A2A messages; no shared mutable state
Data Leakage via LLM	LLM includes sensitive data from one user in another user's response	Per-conversation context isolation; DLP on outputs; no cross-user context

MCP Security — Known Attack Vectors

MCP-Specific Security Risks (2024-2025 Research)

- Tool name collision: malicious MCP server registers tool with same name as trusted tool
- Schema injection: tool description contains hidden instructions to AI (prompt injection via schema)
- Credential exfiltration: rogue MCP server returns tool_result with encoded token-stealing payload
- Scope creep: MCP server requests broader OAuth scopes than tool requires
- Unauthorised tool registration: MCP server list manipulation if not cryptographically signed

Governance — Authorization Models

Enterprise AI governance requires authorization checks at multiple layers. The choice of authorization model (RBAC, ABAC, PBAC, Cedar, OPA) determines how fine-grained and auditable these checks can be.

Authorization Model Comparison

Authorization Model Comparison

Model	Full Name	Granularity	Best For	Example Policy
RBAC	Role-Based Access Control	Role-level	Simple enterprise structures	Developers can read all repos
ABAC	Attribute-Based Access Control	Attribute-level	Dynamic, context-sensitive policies	User in EU can read EU-data only
PBAC	Policy-Based Access Control	Policy-level	Complex compliance rules	Action allowed if MFA in last 5 min
Cedar	Cedar Policy Language (AWS)	Fine-grained entity-based	AWS, Verified Permissions	Policy as code with entity graphs
OPA/Rego	Open Policy Agent	Arbitrary rule complexity	Kubernetes, API gateways	Rego rules evaluated per request

Where Authorization Occurs in the AI Stack

Authorization Enforcement Points

Authorization Point	What is Checked	Who Enforces	Failure Mode
Before LLM (pre-processing)	Is this user allowed to use this AI feature?	AI platform IAM / entitlement service	Request rejected before LLM sees it
After LLM (intent validation)	Is the LLM's intended action permitted?	Policy engine (OPA/Cedar)	Action blocked; user informed; logged
Before tool call	Does user have permission for this specific tool?	Tool orchestrator + policy engine	Tool call blocked; LLM receives 'access denied' tool result
Inside tool (at API)	Does user's OAuth token have required scopes?	Target API (GitHub, ServiceNow, etc.)	API returns 401/403; agent handles gracefully
After tool response	Does response contain data user shouldn't see?	DLP / data classification layer	Response redacted; audit event raised

Authorization Point	What is Checked	Who Enforces	Failure Mode
After LLM response	Does final answer contain sensitive data?	Output DLP / Purview	Response filtered before delivery to user

Microsoft Entra Conditional Access for AI

Conditional Access (CA) policies in Microsoft Entra ID can enforce authentication requirements before users can access AI platforms or specific tools. This provides governance at the IdP layer, upstream of the AI system.

Conditional Access Policies for AI

Condition	Example Policy	AI Agent Impact
MFA Required	All AI platform access requires MFA	User must complete MFA before AI session begins
Compliant Device	AI access only from Intune-managed devices	Blocks AI use from personal/unmanaged devices
Location Restriction	AI access only from corporate IP ranges	Prevents AI use from untrusted networks
Sign-in Risk	High-risk sign-ins blocked from AI	Identity Protection flags risky logins
Session Controls	Limit AI session to 8 hours	Forces re-authentication after absolute timeout
App Restriction	Block AI apps in guest/B2B tenants	External users cannot use AI on corporate data

Complete Audit Chain

A complete enterprise AI audit chain connects every user action to every downstream API call through a set of correlated identifiers. This is essential for compliance, incident investigation, and demonstrating to auditors that AI actions are traceable to human actors.

Complete AI Audit Chain (10 Steps)



Correlation ID Architecture

Correlation ID Taxonomy

Identifier	Scope	Generated By	Used In
user_id (UPN/sub)	Global user identifier	IdP (Entra ID / Okta)	All audit logs; maps all activity to one person
session_id	AI platform session	AI platform on login	Conversation grouping; absolute timeout enforcement
conversation_id	Single conversation	AI platform per conversation start	Groups all turns, tool calls, responses
turn_id	Single user message + response	AI platform per message	Associates prompt with specific LLM response
trace_id	End-to-end distributed trace	OpenTelemetry (W3C traceparent)	Correlates across AI platform, MCP servers, APIs
span_id	Single operation within trace	OpenTelemetry	Individual tool calls, API requests, LLM invocations
token_jti	JWT token instance	IdP (jti claim)	Identifies specific token used for each API call
oauth_client_id	OAuth client (AI app)	OAuth registration	Identifies which AI app performed token exchange
agent_id	AI agent instance	Agent runtime	For multi-agent systems — identifies which agent acted

Audit Log Requirements for Regulated Industries

- SOC 2: Retain audit logs for 1 year; review access logs monthly
- ISO 27001: Log all access to sensitive assets; review logs for anomalies
- PCI DSS: Log all access to cardholder data environment; retain 12 months (3 months online)
- NIST SP 800-53: Centralized log management; tamper-evident log storage; real-time alerting
- GDPR: Log access to personal data; provide audit trail for data subject requests
- Financial regulations (SOX, FCA): Non-repudiation for all financial transactions via AI

SIEM Integration for AI Audit Logs

SIEM Log Source Integration

Log Source	Log Type	SIEM Format	Key Fields
Microsoft Purview	Copilot Activity	CEF / JSON	UserId, ConversationId, ActionType, PolicyResult
Entra ID	Sign-in + Audit	JSON / Log Analytics	UserId, AppId, TokenType, CondAccessStatus

Log Source	Log Type	SIEM Format	Key Fields
GitHub	Org Audit Log	JSON / SIEM streaming	actor, repo, action, programmatic
ServiceNow	sys_audit	JSON / MID Server	user, table, field_name, old_value, new_value
MCP Server	Tool invocation log	JSON / structured	tool_name, user_id, conversation_id, trace_id
Slack	Audit Logs API	JSON	actor, action, entity, context (ip, ua)
Salesforce	Event Monitoring	CSV / JSON	UserId, EventType, ObjectType, QueriedEntities